

Narrativa Explicativa de la Encuesta CWE

Imaginemos, por un momento, que las debilidades de software y hardware no fueran esos entes nebulosos que aparecen en informes post mortem, sino ciudadanos de pleno derecho en nuestros sistemas de gestión. Que tuvieran nombre, apellido y ficha policial. Eso, a grandes rasgos, es lo que pretende CWE, y eso, con algo de mala leche constructiva, es lo que esta encuesta quiere poner frente al espejo de cada organización.

La narrativa que subyace a este cuestionario es sencilla: los incidentes no surgen de la nada. Suelen ser la consecuencia de patrones repetidos de diseño e implementación, catalogables, medibles y, con algo de disciplina, prevenibles. CWE es el inventario global de esos patrones; la encuesta intenta averiguar hasta qué punto su organización se ha decidido a hablar ese idioma, o prefiere seguir en el dialecto local de “parches cuando explota algo”.

En el primer bloque preguntamos por lo más básico: quién es usted, a qué se dedica su organización, cuán grande es el barco y qué mares navega. No por curiosidad estadística, sino porque no es lo mismo hablar de CWE en una startup de doce personas que en un organismo público con millones de ciudadanos dependiendo de sus sistemas.

A continuación, entramos en el terreno del gobierno y la estrategia. Aquí la pregunta de fondo es si la gestión de debilidades está en la partitura estratégica o sigue improvisándose en los ensayos. ¿Existe una política que hable de debilidades, o solo de “vulnerabilidades” en abstracto? ¿Se menciona CWE, aunque sea en letra pequeña, en los planes directores de ciberseguridad? Si la respuesta es no, ya tenemos el primer indicador: la taxonomía existe, pero no ha sido invitada al consejo de administración.

Los siguientes bloques se adentran en la mecánica: cómo se identifican las debilidades, cómo se registran, cómo se clasifican. Preguntamos si las vulnerabilidades (esas CVE que llenan boletines) se vinculan a su causa raíz en CWE y si esta información desemboca en métricas o se queda fosilizada en algún sistema de tickets. Si la clasificación queda a medias, la organización verá árboles (vulnerabilidades individuales), pero no el bosque (los patrones sistémicos).

La parte dedicada a las listas Top 25, KEV y MIHW aborda la cuestión de la **priorización**. Todos sabemos que no hay presupuesto infinito, ni tiempo, ni paciencia. Si la organización dice que trata todas las vulnerabilidades con la misma gravedad, sospeche: o tiene recursos de ciencia ficción, o está haciendo mal las cuentas. Preguntamos entonces si se usan las listas de debilidades más peligrosas, las explotadas activamente o las más relevantes en hardware para orientar formación, pruebas y mitigaciones.

La sección de indicadores y métricas es donde la estadística levanta la ceja. ¿Calcula su organización qué porcentaje de sus hallazgos corresponden a inyección, autenticación, gestión de memoria, control de acceso? ¿Sabe cuánto tarda, de media, en arreglar unas y otras? ¿Ve una tendencia a la baja en ciertas debilidades o vive en una eterna reinvencción del mismo error? Quien responde “no medimos nada de

eso” no está suspenso moralmente, pero sí nos da un dato valioso: aún no ha cruzado la frontera de la gestión basada en evidencias.

El ciclo de vida de desarrollo (SDLC) merece capítulo aparte porque es donde las debilidades nacen, crecen y se reproducen. Preguntamos si CWE está presente desde los requisitos y el diseño o solo aparece, de mala gana, en los informes de pruebas al final del proyecto. Cuanto más tarde entra en escena, más caro y doloroso suele ser corregir sus efectos.

No podíamos dejar fuera la gestión de riesgos y el cumplimiento. Aquí la cuestión es si las debilidades concretas (esas pequeñas joyas de CWE) se conectan con los grandes marcos de siempre: ENS, ISO 27001, NIS2 y otros altares de la seguridad. Si no existe esa traducción, el diálogo entre técnicos y reguladores se parece al de dos personas discutiendo en idiomas distintos: ambos creen tener razón, ninguno se entiende.

Después entran en juego las capacidades y la cultura. Pedimos al encuestado que se sincere: ¿ha recibido alguien formación específica en CWE? ¿Se usan las debilidades como material didáctico, o seguimos con el eterno “no hagas clic en enlaces raros” como si eso arreglara un desbordamiento de buffer? La cultura técnica no se improvisa, y el cuestionario lo sabe.

Los bloques finales abordan la infraestructura de datos y la economía del asunto. De poco sirve querer indicadores si la información se dispersa en diez herramientas incompatibles. Por eso preguntamos por repositorios centralizados, APIs y procesos de integración. Y, porque nadie invierte por amor al arte, preguntamos también por modelos de impacto económico y de retorno de inversión. No para que el encuestado haga una tesis financiera en cada respuesta, sino para saber si su organización ha empezado a mirar las debilidades no solo como un problema técnico, sino como una variable económica.

Todo ello, envuelto en opciones de respuesta que permiten posicionarse sin demasiada poesía, pero con cierto margen de ironía implícita: cuando uno marca “no lo sabemos” demasiadas veces, el mensaje no lo envía al encuestador, sino a su propia dirección.

En resumen, esta encuesta no pretende ser un tribunal, sino un espejo. Uno que habla en el idioma de CWE, CVE, CVSS y compañía, pero que se traduce a decisiones muy humanas: dónde poner el presupuesto, qué formar, qué medir y qué dejar, por fin, de improvisar. Si al rellenarla alguien siente una ligera incomodidad, enhorabuena: es el síntoma habitual cuando la realidad se encuentra con las métricas.